

UNIVERSIDADE FEDERAL DE GOIÁS
INSTITUTO DE INFORMÁTICA
BACHARELADO EM SISTEMAS DE INFORMAÇÃO

Residência Técnica em Sistemas de Informação

Relatório de Segurança e LGPD

SQUAD 04

Versão	Data	Autor
1.0	15/06/2026	MATHEUS PAMPLONA OLIVEIRA
1.1	16/06/2026	BRUNO VINÍCIUS RODRIGUES VIEIRA

1 - Introdução.....	4
2 - Relatório de Impacto à Proteção de Dados (RIPD).....	4
2.1 - Mapeamento de Dados Pessoais.....	4
2.2 - Princípios Aplicados ao Tratamento dos Dados.....	5
2.3 - Base Legal.....	6
a) Execução de Contrato (Art. 7º, V).....	6
b) Cumprimento de Obrigação Legal ou Regulatória (Art. 7º, II).....	7
c) Legítimo Interesse do Controlador (Art. 7º, IX).....	7
d) Execução de Contrato (Art. 7º, V).....	8
2.4 - Riscos Identificados.....	8
2.5 - Mitigações.....	9
a) Criptografia de Senhas.....	10
b) Controle de Acesso Baseado em Papéis (RBAC).....	10
c) Autenticação por Token JWT.....	10
d) Registro de Logs de Auditoria.....	10
e) Comunicação Segura por HTTPS.....	10
f) Princípio do Menor Privilégio.....	10
g) Backup Periódico do Banco de Dados.....	11
h) Monitoramento e Gestão de Incidentes.....	11
i) Atualizações e Correções de Segurança.....	11
j) Minimização e Necessidade dos Dados.....	11
k) Capacitação e Conscientização.....	11
l) Token de Provisionamento com Validade Limitada.....	12
m) Revogação Automática do Token de Provisionamento.....	12
n) Restrição do Escopo de Acesso.....	12
o) Isolamento dos Ambientes das Agências.....	12
p) Registro das Operações de Provisionamento.....	12
q) Gestão do Ciclo de Vida das Credenciais.....	13
3 - Modelo de Controle de Acesso (RBAC).....	13
3.1 - Perfis de Usuário.....	13
Administrador.....	13
Checador.....	14
Curador.....	14
Editor.....	15
Perfil Personalizado.....	15
3.2 - Matriz de Permissões.....	15
3.3 - Hierarquia de Acesso.....	17
3.4 - Fluxos de Acesso.....	18

3.4.1 - Provisionamento Inicial do Ambiente.....	18
3.4.2 - Fluxo Operacional de Autenticação e Autorização.....	18
4 - Considerações Finais.....	19

1 - Introdução

O presente documento tem por finalidade apresentar a análise de conformidade do sistema eFCaaS em relação aos requisitos estabelecidos pela Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018 – LGPD), bem como definir o modelo de Controle de Acesso Baseado em Papéis (Role-Based Access Control – RBAC) adotado pela plataforma.

Considerando que o sistema realiza o tratamento de informações relacionadas aos usuários e registra operações necessárias para o funcionamento da solução, torna-se fundamental estabelecer mecanismos que assegurem a proteção dos dados pessoais, a rastreabilidade das ações executadas e a adequada gestão das permissões de acesso.

Nesse contexto, este documento contempla a elaboração do Relatório de Impacto à Proteção de Dados Pessoais (RIPD), incluindo o mapeamento dos dados tratados, a identificação das bases legais aplicáveis, à análise dos principais riscos relacionados à privacidade e à segurança da informação e a definição das respectivas medidas mitigadoras.

Adicionalmente, é apresentado o modelo de Controle de Acesso Baseado em Papéis (RBAC), responsável por estabelecer os perfis de usuário, a matriz de permissões, a hierarquia de acesso e os fluxos de autenticação e autorização da plataforma, garantindo que os privilégios sejam concedidos de acordo com as responsabilidades de cada perfil e em conformidade com o princípio do menor privilégio.

2 - Relatório de Impacto à Proteção de Dados (RIPD)

2.1 - Mapeamento de Dados Pessoais

O sistema eFCaaS realiza o tratamento de dados pessoais estritamente necessários para a autenticação dos usuários, controle de acesso, rastreabilidade das operações e administração da plataforma. As categorias de dados pessoais tratadas pelo sistema estão descritas na tabela a seguir:

Categoria	Dados Tratados	Finalidade
Identificação	Nome e endereço de e-mail institucional	Identificação dos usuários e gerenciamento das contas de acesso
Autenticação	Senha armazenada de forma criptografada	Garantir a autenticação e a segurança das credenciais de acesso
Auditoria	Data e hora de acesso, histórico de autenticações e logs das operações realizadas	Possibilitar rastreabilidade, monitoramento e investigação de incidentes
Perfil de Usuário	Papel atribuído ao usuário, permissões e nível de acesso associado	Aplicar o modelo de controle de acesso baseado em papéis (RBAC)
Sessão de Usuário	Token de autenticação e informações de sessão	Manter e validar sessões autenticadas durante a utilização da plataforma
Dados Operacionais	Registros relacionados às ações executadas pelos usuários na plataforma	Garantir a integridade das operações e apoiar processos de auditoria
Assinatura	Identificador da agência, plano contratado e período de vigência	Controle do licenciamento e provisionamento
Tokens de Provisionamento	Token da agência e chaves de acesso	Configuração inicial do ambiente
Ambiente da Agência	Identificador do tenant e configurações específicas	Isolamento entre agências

2.2 - Princípios Aplicados ao Tratamento dos Dados

O tratamento dos dados pessoais realizado pela plataforma observa os princípios previstos na LGPD, em especial:

- **Finalidade:** os dados são utilizados exclusivamente para os propósitos relacionados à operação e segurança da plataforma;
- **Adequação:** o tratamento é compatível com as finalidades informadas aos titulares;

- **Necessidade:** são coletados apenas os dados estritamente necessários para a prestação dos serviços;
- **Segurança:** são adotadas medidas técnicas e administrativas para proteção das informações;
- **Prevenção:** são implementados controles destinados à redução dos riscos associados ao tratamento dos dados;
- **Responsabilização e prestação de contas:** as operações realizadas são registradas e podem ser auditadas.

O mapeamento apresentado constitui a base para a identificação dos riscos associados ao tratamento dos dados pessoais e para a definição das medidas de mitigação descritas nas seções subsequentes deste documento.

2.3 - Base Legal

O tratamento dos dados pessoais realizado pela plataforma está fundamentado nas hipóteses legais previstas na Lei nº 13.709/2018 (Lei Geral de Proteção de Dados Pessoais – LGPD), garantindo que toda atividade envolvendo coleta, armazenamento, processamento, consulta e compartilhamento de informações ocorra em conformidade com a legislação vigente.

a) Execução de Contrato (Art. 7º, V)

Os dados pessoais são tratados quando necessários para a execução de contratos ou de procedimentos preliminares relacionados ao contrato, dos quais o titular e seus colaboradores fazem parte.

Essa base legal é aplicada, por exemplo, para:

- Realização do cadastro e autenticação de usuários na plataforma;
- Prestação dos serviços oferecidos pelo sistema;
- Processamento e gerenciamento das solicitações realizadas pelos usuários;
- Manutenção do histórico de operações necessárias para a continuidade e correta execução dos serviços.

O tratamento é limitado às informações estritamente necessárias para a prestação dos serviços contratados.

b) Cumprimento de Obrigação Legal ou Regulatória (Art. 7º, II)

Determinados dados pessoais podem ser tratados em razão de exigências impostas por legislação específica ou por órgãos reguladores competentes.

Entre as finalidades relacionadas a essa base legal estão:

- Atendimento a obrigações fiscais, tributárias e administrativas;
- Conservação de registros e evidências exigidos por lei;
- Disponibilização de informações mediante requisição de autoridades competentes;
- Implementação de medidas de auditoria, rastreabilidade e conformidade.

Nesses casos, a retenção dos dados observará os prazos legais e regulatórios aplicáveis.

c) Legítimo Interesse do Controlador (Art. 7º, IX)

O tratamento de dados pessoais também poderá ocorrer quando necessário para atender aos interesses legítimos do controlador, desde que sejam respeitados os direitos e as liberdades fundamentais dos titulares dos dados.

Essa hipótese é utilizada para:

- Garantir a segurança da informação e a prevenção de fraudes;
- Monitorar a utilização da plataforma para identificação de incidentes e comportamentos anômalos;
- Realizar melhorias contínuas nos serviços oferecidos;
- Produzir estatísticas e métricas operacionais de forma compatível com os princípios da necessidade e minimização dos dados;
- Assegurar a continuidade, disponibilidade e desempenho da solução.

Sempre que aplicada, a utilização do legítimo interesse é precedida de avaliação quanto à necessidade, proporcionalidade e impacto sobre os direitos dos titulares,

adotando-se medidas técnicas e administrativas adequadas para mitigar riscos e preservar a privacidade.

d) Execução de Contrato (Art. 7º, V)

Além da autenticação e utilização da plataforma, essa base legal também fundamenta:

- Provisionamento do ambiente da agência;
- Gestão das assinaturas;
- Emissão de tokens de acesso;
- Manutenção e suporte da plataforma.

2.4 - Riscos Identificados

Com base na análise dos processos de tratamento de dados pessoais realizados pela plataforma eFCaaS, foram identificados os principais riscos relacionados à confidencialidade, integridade e disponibilidade das informações.

Risco Identificado	Descrição	Impacto
Acesso não autorizado	Possibilidade de usuários ou terceiros acessarem informações sem as devidas permissões.	Alto
Vazamento de informações	Exposição acidental ou intencional de dados pessoais e informações sensíveis armazenadas ou processadas pela plataforma.	Alto
Roubo de credenciais	Comprometimento de contas de usuários em decorrência de senhas fracas, reutilização de credenciais ou ataques maliciosos.	Alto
Alteração indevida dos dados	Modificação não autorizada de registros, conteúdos ou informações processadas pelo sistema.	Médio
Falhas no processo de autenticação	Erros ou vulnerabilidades que permitam acessos indevidos ou indisponibilidade do mecanismo de autenticação.	Médio
Escalada de privilégios	Obtenção indevida de permissões superiores às atribuídas originalmente ao usuário.	Alto

Perda ou indisponibilidade dos dados	Falhas operacionais, corrupção do banco de dados ou indisponibilidade dos serviços que impeçam o acesso às informações.	Médio
Exclusão accidental de informações	Remoção indevida de registros ou conteúdos em decorrência de falhas humanas ou problemas operacionais.	Médio
Falhas na rastreabilidade das operações	Ausência ou inconsistência de registros de auditoria que dificultem a investigação de incidentes e a responsabilização das ações realizadas.	Médio
Vulnerabilidades em componentes da aplicação	Exploração de falhas de segurança em bibliotecas, APIs ou serviços utilizados pela plataforma.	Alto
Uso indevido do token de provisionamento	Utilização não autorizada do token temporário destinado à configuração inicial do ambiente da agência.	Baixo
Exposição do token de provisionamento	Vazamento do token antes da conclusão da configuração inicial.	Baixo

Os riscos identificados foram classificados de acordo com seu potencial impacto sobre a confidencialidade, integridade e disponibilidade das informações, bem como sobre os direitos e liberdades dos titulares dos dados.

A análise dos riscos serviu como base para a definição das medidas técnicas e administrativas apresentadas na Seção 2.5, visando reduzir a probabilidade de ocorrência desses eventos e minimizar seus impactos sobre a operação da plataforma eFCaaS.

Os riscos e respectivas medidas de mitigação deverão ser revisados periodicamente, em consonância com a evolução da arquitetura do sistema, das ameaças de segurança e dos requisitos regulatórios aplicáveis.

2.5 - Mitigações

Com o objetivo de reduzir os riscos associados ao tratamento de dados pessoais e garantir a confidencialidade, integridade e disponibilidade das informações, serão

implementadas medidas técnicas e administrativas alinhadas às boas práticas de segurança da informação e aos princípios estabelecidos pela LGPD.

a) Criptografia de Senhas

As credenciais dos usuários serão armazenadas utilizando algoritmos de hash criptográfico adequados, impossibilitando a recuperação direta das senhas em caso de acesso não autorizado à base de dados.

b) Controle de Acesso Baseado em Papéis (RBAC)

O acesso às funcionalidades do sistema será restrito de acordo com os perfis de usuário definidos, garantindo que cada usuário possua apenas as permissões necessárias para a execução de suas atividades.

c) Autenticação por Token JWT

Os mecanismos de autenticação serão implementados por meio de JSON Web Tokens (JWT), permitindo a validação segura das sessões e reduzindo os riscos de acesso indevido aos recursos da aplicação.

d) Registro de Logs de Auditoria

Serão mantidos registros das operações relevantes realizadas no sistema, possibilitando rastreabilidade, monitoramento de eventos, identificação de incidentes de segurança e apoio em processos de auditoria.

e) Comunicação Segura por HTTPS

Toda a comunicação entre clientes e servidores será protegida por protocolos criptografados (HTTPS/TLS), garantindo a confidencialidade e a integridade dos dados transmitidos.

f) Princípio do Menor Privilégio

Os usuários, serviços e componentes do sistema receberão apenas os privilégios estritamente necessários para a execução de suas funções, minimizando o impacto potencial de falhas, acessos indevidos ou comprometimentos.

g) Backup Periódico do Banco de Dados

Serão realizados procedimentos regulares de backup das informações armazenadas, visando assegurar a disponibilidade dos dados e possibilitar a recuperação em casos de falhas, perda de informações ou desastres.

h) Monitoramento e Gestão de Incidentes

Serão adotados mecanismos de monitoramento contínuo e procedimentos para identificação, registro e tratamento de incidentes de segurança, permitindo respostas rápidas e reduzindo impactos sobre os titulares dos dados.

i) Atualizações e Correções de Segurança

Os componentes da infraestrutura e da aplicação serão mantidos atualizados, com aplicação periódica de correções e patches de segurança, visando reduzir vulnerabilidades conhecidas e fortalecer a proteção do ambiente.

j) Minimização e Necessidade dos Dados

O sistema coletará e processará apenas os dados estritamente necessários para o cumprimento das finalidades definidas, observando os princípios da adequação, necessidade e minimização previstos na LGPD.

k) Capacitação e Conscientização

Os responsáveis pela administração e operação da plataforma deverão observar boas práticas de segurança da informação e proteção de dados, promovendo a utilização adequada dos recursos e a prevenção de incidentes decorrentes de falhas humanas.

As medidas descritas serão revisadas periodicamente, de modo a garantir sua efetividade e adequação diante da evolução tecnológica, das mudanças regulatórias e dos riscos identificados ao longo do ciclo de vida do sistema.

l) Token de Provisionamento com Validade Limitada

Para a configuração inicial de novos ambientes, o sistema disponibilizará um token temporário de provisionamento destinado exclusivamente ao Administrador da Agência. Esse token possuirá prazo de validade previamente definido e será utilizado apenas durante o processo de inicialização do ambiente.

m) Revogação Automática do Token de Provisionamento

Após a conclusão da configuração inicial, ou em caso de expiração do prazo estabelecido, o token de provisionamento será automaticamente invalidado, impedindo sua reutilização e reduzindo os riscos associados à exposição de credenciais temporárias.

n) Restrição do Escopo de Acesso

O token de provisionamento possuirá permissões limitadas às operações necessárias para a criação e configuração inicial do ambiente da agência, não sendo utilizado para atividades operacionais ou para autenticação regular dos usuários da plataforma.

o) Isolamento dos Ambientes das Agências

Cada agência de checagem operará em um ambiente logicamente segregado, garantindo que os dados, configurações e usuários de uma organização não sejam acessíveis por outras agências, preservando a confidencialidade e a integridade das informações processadas.

p) Registro das Operações de Provisionamento

As atividades realizadas durante o processo de configuração inicial do ambiente serão registradas em logs de auditoria, permitindo a rastreabilidade das ações executadas e apoiando a identificação e investigação de eventuais incidentes de segurança.

q) Gestão do Ciclo de Vida das Credenciais

As credenciais permanentes dos usuários serão estabelecidas somente após a conclusão do processo de provisionamento. A partir desse momento, todos os acessos à plataforma serão realizados por meio dos mecanismos padrão de autenticação e autorização, utilizando JSON Web Tokens (JWT) e o modelo de Controle de Acesso Baseado em Papéis (RBAC).

As medidas descritas serão revisadas periodicamente, de modo a garantir sua efetividade e adequação diante da evolução tecnológica, das mudanças regulatórias e dos riscos identificados ao longo do ciclo de vida do sistema.

3 - Modelo de Controle de Acesso (RBAC)

Com o objetivo de garantir a segurança das informações e assegurar que cada usuário possua apenas os acessos necessários para o desempenho de suas funções, a plataforma adotará o modelo de Controle de Acesso Baseado em Papéis (Role-Based Access Control – RBAC).

Nesse modelo, as permissões são associadas a perfis de usuário previamente definidos, permitindo uma administração centralizada dos privilégios e reduzindo os riscos decorrentes de acessos indevidos.

3.1 - Perfis de Usuário

Foram estabelecidos quatro perfis principais de acesso, cujas responsabilidades e níveis de privilégio são descritos a seguir.

Administrador

O perfil de Administrador possui o mais alto nível de privilégio dentro da plataforma, sendo responsável pela administração geral do ambiente e pela gestão dos demais usuários.

Suas principais atribuições incluem:

- Gerenciar contas de usuários;
- Criar, editar e remover perfis de acesso;
- Configurar permissões e parâmetros do sistema;
- Monitorar registros e logs de auditoria;
- Gerenciar conteúdos e publicações em todas as etapas do fluxo;
- Realizar atividades de manutenção e suporte administrativo.

Checador

O perfil de Checador é responsável pela análise e verificação das informações submetidas à plataforma.

Entre suas atribuições estão:

- Acessar conteúdos destinados à checagem;
- Realizar análises e verificações das informações;
- Produzir pareceres e evidências relacionadas ao processo de validação;
- Atualizar o status das verificações realizadas;
- Encaminhar conteúdos para revisão e curadoria.

O perfil de Checador não possui privilégios administrativos ou permissões para publicação final.

Curador

O perfil de Curador é responsável pela revisão e validação dos conteúdos produzidos pelos checadores, garantindo a qualidade e a consistência das informações.

Suas atribuições incluem:

- Revisar conteúdos analisados;
- Submeter conteúdos para análise;
- Aprovar ou solicitar ajustes nas verificações realizadas;
- Garantir a conformidade editorial e metodológica das publicações;
- Encaminhar conteúdos aprovados para publicação.

Editor

O perfil de Editor é responsável pela gestão e disponibilização dos conteúdos ao público.

Entre suas responsabilidades estão:

- Publicar conteúdos aprovados;
- Editar elementos textuais e visuais das publicações;
- Atualizar ou remover conteúdos quando necessário;
- Gerenciar o fluxo editorial da plataforma.

Perfil Personalizado

A plataforma permite a criação de perfis personalizados, possibilitando que cada agência de checagem configure permissões específicas de acordo com sua estrutura organizacional e seus processos internos.

Esses perfis poderão ser definidos pelo Administrador e possuir diferentes níveis de acesso às funcionalidades da plataforma, respeitando os princípios de necessidade e do menor privilégio.

Todos os perfis de acesso são definidos de forma a garantir que cada usuário tenha acesso apenas aos recursos estritamente necessários para o desempenho de suas funções, contribuindo para a proteção dos dados, a rastreabilidade das operações e a segurança da informação.

3.2 - Matriz de Permissões

A plataforma implementa um modelo de Controle de Acesso Baseado em Papéis (RBAC), no qual as permissões são atribuídas conforme as responsabilidades de cada perfil. A tabela a seguir apresenta as permissões padrão da solução.

Funcionalidade	Administrador	Checador	Curador	Editor	Perfil Personalizado
Realizar login	✓	✓	✓	✓	✓
Gerenciar perfil próprio	✓	✓	✓	✓	Configurável
Consultar conteúdos	✓	✓	✓	✓	Configurável
Criar análises e verificações	✓	✓	X	X	Configurável
Editar análises próprias	✓	✓	X	X	Configurável
Revisar análises	✓	X	✓	X	Configurável
Aprovar ou reprovar conteúdos	✓	X	✓	X	Configurável
Encaminhar conteúdo para publicação	✓	X	✓	X	Configurável
Editar conteúdos publicados	✓	X	X	✓	Configurável
Publicar conteúdos	✓	X	X	✓	Configurável
Despublicar conteúdos	✓	X	X	✓	Configurável
Gerenciar usuários	✓	X	X	X	Configurável
Criar e alterar perfis de acesso	✓	X	X	X	Configurável
Configurar parâmetros do sistema	✓	X	X	X	X
Consultar logs de auditoria	✓	X	✓	X	Configurável
Exportar relatórios	✓	✓	✓	✓	Configurável
Gerenciar conteúdos em todas as etapas do fluxo	✓	X	X	X	Configurável

Perfil Personalizado: As agências de checagem poderão definir papéis específicos e atribuir permissões conforme suas necessidades operacionais, respeitando os princípios da necessidade e do menor privilégio.

As permissões apresentadas representam a configuração padrão da plataforma. Os acessos são concedidos de acordo com as responsabilidades de cada perfil, buscando garantir a segregação de funções, a rastreabilidade das operações e a proteção dos dados processados pelo sistema.

3.3 - Hierarquia de Acesso

A plataforma adota uma estrutura hierárquica de privilégios baseada no modelo RBAC, na qual cada perfil possui um conjunto específico de permissões de acordo com suas responsabilidades no fluxo de verificação e publicação de conteúdos.

A hierarquia padrão de acesso é definida da seguinte forma:



3.4 - Fluxos de Acesso

O processo de autenticação e autorização da plataforma eFCaaS é dividido em duas etapas principais: o provisionamento inicial do ambiente da agência e o fluxo operacional regular dos usuários. Essa abordagem permite estabelecer mecanismos de segurança adequados desde a implantação do ambiente até sua utilização cotidiana.

3.4.1 - Provisionamento Inicial do Ambiente

Após a contratação da plataforma, é disponibilizado ao Administrador da Agência um token temporário de provisionamento, destinado exclusivamente à configuração inicial do ambiente.

Durante essa etapa, o administrador poderá:

- Realizar a ativação do ambiente da organização;
- Definir configurações iniciais da plataforma;
- Criar os primeiros usuários da agência;
- Estabelecer os perfis e permissões de acesso necessários para a operação;
- Configurar parâmetros específicos da organização.

Concluído o processo de inicialização, o token de provisionamento é automaticamente revogado, impedindo sua reutilização e garantindo que os acessos subsequentes sejam realizados exclusivamente pelos mecanismos padrão de autenticação da plataforma.

3.4.2 - Fluxo Operacional de Autenticação e Autorização

Após a conclusão do provisionamento, os usuários passam a acessar a plataforma por meio do fluxo regular de autenticação e autorização.

O processo ocorre conforme as seguintes etapas:

1. O usuário fornece suas credenciais de acesso à plataforma por meio de conexão segura utilizando HTTPS;

2. O sistema realiza a validação das credenciais apresentadas e verifica a situação da conta do usuário;
3. Em caso de autenticação bem-sucedida, é emitido um JSON Web Token (JWT), responsável por identificar a sessão do usuário;
4. O sistema identifica o perfil RBAC associado ao usuário, determinando suas funções e permissões;
5. As regras de autorização são aplicadas de acordo com o perfil atribuído, observando os princípios da segregação de funções e do menor privilégio;
6. As operações solicitadas são executadas somente quando compatíveis com as permissões do perfil do usuário;
7. Todas as ações relevantes realizadas na plataforma são registradas em logs de auditoria, permitindo rastreabilidade e monitoramento;
8. Ao término da sessão ou após a expiração do token JWT, uma nova autenticação será necessária para restabelecimento do acesso.

Esse fluxo contribui para garantir a confidencialidade, integridade, disponibilidade e rastreabilidade das informações processadas pelo sistema eFCaaS, fortalecendo a segurança da informação e a conformidade com os requisitos da Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018).

4 - Considerações Finais

A adoção das medidas apresentadas neste documento contribui para a proteção dos dados pessoais tratados pelo sistema eFCaaS, promovendo maior segurança da informação, rastreabilidade das operações e conformidade com os requisitos estabelecidos pela Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018).

Por meio da elaboração do Relatório de Impacto à Proteção de Dados Pessoais (RIPD), do mapeamento dos dados tratados, da identificação das bases legais aplicáveis e da definição das medidas mitigatórias, buscou-se estabelecer mecanismos capazes de reduzir riscos relacionados à privacidade e fortalecer a governança dos dados processados pela plataforma.

Adicionalmente, a implementação do modelo de Controle de Acesso Baseado em Papéis (Role-Based Access Control – RBAC) proporciona uma gestão mais eficiente dos privilégios de acesso, permitindo a segregação de funções, a aplicação do princípio do menor privilégio e a definição de perfis adaptáveis às necessidades específicas das agências de checagem que utilizarem a solução.

Os mecanismos de autenticação, autorização e auditoria descritos neste documento também contribuem para assegurar a confidencialidade, integridade e disponibilidade das informações, além de possibilitar maior rastreabilidade das operações realizadas pelos usuários da plataforma.

Ressalta-se que as medidas e controles aqui descritos deverão ser revisados periodicamente, de forma a acompanhar a evolução dos requisitos legais, das ameaças à segurança da informação e das necessidades operacionais do sistema, garantindo a manutenção da conformidade regulatória e a melhoria contínua dos processos relacionados à proteção de dados.

Dessa forma, o presente documento estabelece uma base para a governança de dados e para a implementação de práticas de segurança alinhadas às diretrizes da LGPD, contribuindo para a confiabilidade, transparência e sustentabilidade da solução eFCaaS ao longo de seu ciclo de vida.